



DORA

Digital Operational Resilience Act

Noureddine Kanzari

Chapter 1

About the author

Noureddine Kanzari is a cybersecurity expert with an extensive background in IT risk management and cybersecurity instruction. With a diverse range of certifications that includes being a PECB Certified Trainer, DORA Senior Lead Manager, NIST Cybersecurity Consultant, Senior Lead Incident Manager, Senior Lead SOC 2 Analyst, Data Protection Officer (DPO), DORA Senior Lead Manager, ISO 42001 Senior Lead Auditor, ISO 42001 Senior Lead Implementer, Senior Lead SCADA Security Manager, ISO 22301 Senior Lead Implementer, ISO 22301 Senior Lead Auditor, EBIOS Risk Manager, ISO 27005 Senior Lead Risk Manager, ISO 27001 Senior Lead Implementer, ISO 27001 Senior Lead Auditor, Cisco Certified Specialist in Security Core and Enterprise Core, NSE4 Network Security Professional, Palo Alto Instructor, Devops Tools Engineer, LPIC-3 Enterprise Professional Security, LPIC-3 Enterprise Professional Virtualization & High Availability, LPIC-2, LPIC-1, Suse Certified Linux Administration, and a Certified Security Auditor in computer security,

Noureddine Kanzari's professional journey is characterized by a series of impactful roles and accomplishments. Throughout his career, he has held various pivotal positions, including:

Chief Information Security Officer (CISO)

Audit Team Leader

Cybersecurity Instructor

Technical Manager

Training Manager

His extensive experience and leadership have contributed significantly to enhancing cybersecurity practices, risk management strategies, and organizational resilience.

Contents

1. Course Objectives	5
2. Introduction	6
2.1 What is DORA?	6
2.2 Why DORA Exists ?	6
2.3 What Does “DIGITAL OPERATIONAL RESILIENCE” means?	7
Scenario 1 : Preparing Before a Cyber Incident	8
Scenario 2: Service Continuity	8
Scenario 3 : Immediate Response	8
Scenario 4 : Service Recovery	9
Scenario 5 : Post-Incident Improvement	9
2.4 What does DORA try to achieve?	10
Scenario 1: Fast Recovery after a Cyberattack	11
Scenario 2: Business Continuity	11
2.5 Who must follow DORA?	12
Scenario 1: Scope of DORA	12
Scenario 2: Banking Services and DORA	13
Scenario 3: DORA and Insurance Companies	13
Scenario 4 : DORA for Investment Firms	14
Scenario 5 : DORA and Payment Service Providers	14
Scenario 6 : Digital Wallet Companies and DORA	15
Scenario 7: DORA and Crypto Service Providers	15
2.6 Third-Party ICT Providers	16
Scenario 1 : DORA Third-Party ICT Provider	17
Scenario 2 : Cloud Services in DORA	17
Scenario 3: Hosting Under DORA	18

Scenario 4 : DORA Third-Party ICT Provider	18
2.7 Flexibility of DORA	19
Scenario 1 : DORA Proportionality	19
Scenario 2 : Principle of Proportionality	20
Scenario 3 : Risk-Based Application of DORA	21
2.8 The main parts of DORA	22
Scenario 1 : DORA ICT Risk Management	23
Scenario 2 : DORA and Phishing Protection	24
Scenario 3 : DORA and Incident Management	24
2.9 Cybersecurity Measures	25
2.10 Incident response	26
2.11 Third-party risk management	29
2.12 What DORA expects from companies	30
2.13 PRACTICAL EXERCISE 1	31
2.14 EXERCISE 2 – True or False	33
2.15 PRACTICAL EXERCISE 3	34
3. DORA Regulation	37
3.1 When was DORA adopted?	37
3.2 Why is DORA important for financial stability?	38
4. DORA Requirement	39
Scenario 1 : Cyber Risk Management in DORA	39
Scenario 2 : DORA Incident Detection and Reporting	40
Scenario 3 : DORA Testing Requirements	40
Scenario 4 : DORA and Cloud Provider Responsibility	41
Scenario 5: DORA and Cyber Threat Sharing	41
5. Penalties	42
Scenario 1: DORA Penalties	42

1. Course Objectives

At the end of this DORA course, you will be able to:

- Understand what DORA is and why it is important
- Explain why DORA was created
- Understand what DORA expects financial organizations to do
- Interpret DORA requirements in a simple and practical way
- Identify IT risks before they become serious problems
- Know how to respond when an IT incident happens
- Understand the importance of business continuity during IT disruptions
- Learn how to prepare an organization for DORA compliance
- Apply the 5 main pillars of DORA in the organization:
 - ICT Risk Management
 - ICT Incident Reporting
 - Digital Operational Resilience Testing
 - Third-Party ICT Risk Management
 - Information Sharing
- Promote a mindset of continuous improvement for long-term resilience

2. Introduction

2.1 What is DORA?

DORA stands for Digital Operational Resilience Act. It is a European Union (EU) regulation. It was created to make sure that financial companies can continue working when they face digital or technology-related problems.

DORA is an EU law that helps financial companies stay strong and continue their services when digital problems happen.

2.2 Why DORA Exists ?

Today, financial companies depend heavily on technology. They use:

- Online banking systems
- Mobile applications
- Payment platforms
- Cloud services
- Customer databases
- Email systems
- Communication tools
- Online investment platforms

Because of this, they are exposed to more digital risks such as:

- Cyberattacks
- Hacking
- Phishing
- Malware
- Ransomware
- System failures
- Server crashes
- Cloud outages
- Software bugs

- Data loss
- Service interruptions

The financial sector uses technology every day. If the technology fails, the service may fail too. That is why DORA is important.

Example:

If a bank loses access to its digital systems:

- Customers cannot use mobile banking
- Payments may stop
- Transfers may fail
- Services may be unavailable

DORA makes financial companies prepare for digital emergencies the same way a hospital prepares for physical emergencies.

2.3 What Does “DIGITAL OPERATIONAL RESILIENCE” means?

It means the company can:

- Prepare before a digital problem
- Continue operating during the problem
- Respond correctly
- Recover quickly
- Improve after the event
- Prepare + Protect + Respond + Recover + Improve = Digital Resilience

Scenario 1 : Preparing Before a Cyber Incident

A bank knows that cyberattacks can happen. So, before any incident, it creates:

- A backup plan
- Emergency contacts
- Staff training
- Clear security rules

Question :

What did the bank do before the problem happened?

Solution:

The bank prepared in advance by making plans, training employees, and organizing resources.

Scenario 2: Service Continuity

The online banking app stops working for some customers. But customers can still:

- Use ATMs
- Call customer service
- Make urgent transfers through another system

Question:

How does the bank continue serving customers during the outage?

Solution:

The bank uses alternative channels (ATM, phone support, backup systems) so critical services continue.

Scenario 3 : Immediate Response

A phishing email enters the company network. The IT security team:

- Blocks the suspicious email
- Disconnects affected computers
- Informs employees
- Starts an internal investigation

Question:

What should the company do immediately after detecting the phishing attack?

Solution:

The company should respond quickly by containing the threat, protecting systems, and alerting staff.

Scenario 4 : Service Recovery

A server crashes and customer payment services stop. The company restores the system using:

- Backup servers
- Saved data
- Disaster recovery procedures

After 2 hours, services work again.

Question:

How can the company return to normal after the server crash?

Solution:

The company should recover quickly by using backups, recovery plans, and technical support.

Scenario 5 : Post-Incident Improvement

After a ransomware attack, the company discovers:

- Some employees clicked unsafe links
- Some systems were not updated
- Backup tests were too old

So the company:

- Gives new training
- Updates systems
- Improves backup testing
- Strengthens controls

Question :

What should the company do after the incident is finished?

Solution:

The company should analyze the incident, learn lessons, and improve its people, systems, and processes.

2.4 What does DORA try to achieve?

DORA gives one common framework for financial companies in the EU.

It helps them :

- Withstand digital incidents (keep working)
- Recover after disruptions (return to normal)
- Adapt and improve after incidents (learn and become stronger)

DORA wants financial companies to be ready before a problem, react well during the problem, and recover after the problem.

Scenario 1: Fast Recovery after a Cyberattack

A bank has a cyberattack. Its online banking service stops for 2 hours. Because the bank followed DORA, it already had:

- A backup system
- An incident response plan
- A recovery team

The bank quickly switches to backup systems, informs customers, and restores services faster.

Question:

Why was the bank able to continue and recover quickly after the cyberattack?

Solution:

The bank was able to recover quickly because it followed DORA principles:

- It was prepared before the incident,
- It reacted well during the incident,
- It had a plan to recover after the incident.

So, DORA helps financial companies become stronger, faster, and more resilient against digital problems.

Scenario 2: Business Continuity

A payment company has a system failure, but it uses a backup system and continues service.

Question:

What does DORA help the company do?

Answer :

DORA helps the company:

- Stay operational
- Recover fast
- Improve for the future

2.5 Who must follow DORA?

DORA applies to many types of financial entities.

Examples :

- Banks
- Insurance companies
- Investment firms
- Payment service providers
- Electronic money institutions
- Some cryptocurrency service providers
- Other financial organizations

DORA is not only for banks. It applies to many financial companies.

Scenario 1: Scope of DORA

A company says: "We work in finance, but we are not a bank, so DORA is probably not for us."

Question:

Is DORA only for banks?

Solution:

No.

DORA is not only for banks. It applies to many financial entities in the financial sector.

If a company gives financial services, it may need to follow DORA.

Scenario 2: Banking Services and DORA

A bank uses online banking services and mobile apps for customers.

Question:

Does a bank need to follow DORA?

Solution:

Yes.

A bank must follow DORA because it is a financial entity and uses ICT systems (computers, apps, networks).

If the bank has a cyberattack or system failure, customers can be affected.

Scenario 3: DORA and Insurance Companies

An insurance company stores customer contracts and claims in digital systems.

Question:

Does an insurance company need to follow DORA?

Solution:

Yes.

An insurance company must follow DORA because it uses digital tools to manage important customer data and services. DORA helps the company stay secure and resilient.

Scenario 4 : DORA for Investment Firms

An investment firm uses trading software to buy and sell financial products for clients.

Question:

Is DORA important for an investment firm?

Solution:

Yes.

An investment firm must follow DORA because it depends on technology for trading and client services.

If the system stops, financial operations may be disrupted.

Scenario 5 : DORA and Payment Service Providers

A company allows customers to pay online by card or mobile app.

Question:

Does a payment service provider need to follow DORA?

Solution:

Yes.

A payment service provider must follow DORA because it handles digital payments.

If its system fails, customers may not be able to pay or receive money.

Scenario 6 : Digital Wallet Companies and DORA

A fintech company offers a digital wallet where users can store and send electronic money.

Question:

Does a digital wallet company fall under DORA?

Solution:

Yes.

An electronic money institution must follow DORA because it manages electronic money and digital financial services.

It must protect its ICT systems and customer services.

Scenario 7: DORA and Crypto Service Providers

A crypto platform lets users buy, sell, or store cryptocurrencies online.

Question:

Can a cryptocurrency service provider be covered by DORA?

Solution:

Yes, some of them.

Some cryptocurrency service providers may need to follow DORA, depending on their role and the rules that apply to them.

If they provide financial-related digital services, DORA may apply.

2.6 Third-Party ICT Providers

A third-party ICT is an external company that provides technology services.

Examples :

- cloud provider
- hosting provider
- software vendor
- cybersecurity company
- managed IT services provider
- data center provider

Example:

A bank stores customer data in the cloud. If the cloud provider has a major outage:

- the bank may lose access to data
 - online banking may stop
 - customers may be affected
-
- If the external provider fails, the financial company may also fail.

Then:

DORA applies to many financial entities, not only banks. It covers organizations such as payment institutions, e-money companies, investment firms, crypto-asset service providers, and financial market infrastructures. In simple terms, DORA applies to financial organizations that rely on digital systems and need to manage ICT and cyber risks.

Scenario 1 : DORA Third-Party ICT Provider

A bank uses another company to store customer data and run some IT systems.

This company is not part of the bank, but it supports the bank's technology services.

Question:

Is this external company a third-party ICT provider?

Solution:

Yes.

Because it is an outside company that provides technology services to the bank, it is a third-party ICT provider.

Scenario 2 : Cloud Services in DORA

A financial company saves its documents and applications on Microsoft Azure or AWS instead of using its own physical servers.

Question:

What type of third-party ICT provider is this?

Solution:

This is a cloud provider.

It provides technology resources over the internet, such as storage and computing power.

Scenario 3: Hosting Under DORA

An insurance company has a customer portal website.
It pays an external company to keep the website online 24/7.

Question:

What type of provider is helping the insurance company?

Solution:

This is a hosting provider.
Its job is to host the website or application so users can access it anytime.

Scenario 4 : DORA Third-Party ICT Provider

A bank buys an anti-money laundering software tool from an external company to monitor suspicious transactions.

Question:

What type of third-party ICT provider is this?

Solution:

This is a software vendor.
The company is providing software that the bank uses for its operations.

2.7 Flexibility of DORA

Each organization should apply DORA based on:

- Its size
- Its level of risk
- How complex its services and operations are

In other words :

- ➔ A small company may not need the same level of controls as a large and complex financial institution.
- ➔ DORA does not expect every company to do exactly the same thing. A small company and a large bank do not have the same risks. So, DORA allows organizations to apply the rules based on their size, risk, and complexity.

For example, a small payment company may need simpler controls than a large international bank because the bank has more customers, more systems, and higher risk exposure.

Scenario 1 : DORA Proportionality

A small fintech company has 10 employees, one online payment application, and only works in one country.

A large bank has 5,000 employees, many digital services, mobile apps, online banking, ATMs, and works in several countries.

Question:

Should the small fintech and the large bank apply DORA in exactly the same way?

Solution:

No.

DORA says organizations should apply the rules according to:

- how big they are,
- how much risk they have,
- and how complex their systems are.

So:

- the small fintech may need simpler controls,
- the large bank needs stronger and more detailed controls.

Scenario 2 : Principle of Proportionality

A small insurance startup stores customer data in one cloud platform and uses one internal system.

A large international insurance company uses:

- several cloud platforms,
- many applications,
- external vendors,
- and multiple data centers.

Question :

Does the small startup need the same number of controls and security measures as the large international company?

Solution:

No.

The small startup may need:

- basic cybersecurity controls,
- simple incident reporting,
- and regular backups.

The large company may need:

- advanced monitoring,
- stronger vendor management,
- complex testing,
- and more formal risk processes.

Why?

Because the large company is more complex and has more exposure to ICT risk.

Scenario 3 : Risk-Based Application of DORA

A small investment firm has 200 clients and offers only one online service.

A large bank has millions of customers, credit cards, loans, mobile banking, and international transactions.

Question:

Why does DORA allow different levels of implementation for these two organizations?

Solution:

Because their risk is different.

- The small investment firm has fewer systems, fewer customers, and lower operational impact.
- The large bank has many services and customers, so an ICT failure could affect millions of people.

That is why DORA is flexible:

- It does not force the same exact controls for everyone,
- It asks each organization to apply DORA in a proportionate way.

Key idea:

Same regulation, but not always the same level of effort.

2.8 The main parts of DORA

- ICT Risk Management
- Cybersecurity Protection
- Incident Response
- Testing
- Incident Reporting
- Third-Party Risk Management

What is ICT ?

ICT = Information and Communication Technology

It includes :

- Computers
- Applications
- Servers
- Networks
- Databases
- Cloud systems
- Communication tools

What is ICT risk management?

It means a company must:

- Identify digital risks
- Understand digital risks
- Manage those risks
- Reduce the chance of failure

Examples of ICT vulnerabilities :

- Weak passwords
- Outdated software
- No backup
- Poor access control
- No monitoring
- No emergency plan
- Too much dependence on one provider

DORA says: know your digital risks before they become real problems.
--

Scenario 1 : DORA ICT Risk Management

A bank uses an old software system for customer transactions.

The IT team discovers that the system is outdated and may stop working during a peak business day.

Question:

What should the bank do under DORA?

Solution :

The bank should :

- Identify the risk,
- Assess how serious it is,
- Update or replace the system,
- Put controls in place to reduce the risk.

Scenario 2 : DORA and Phishing Protection

An employee receives a fake email asking for login credentials.
The email is actually a phishing attack.

Question:

How does DORA help in this situation?

Solution:

The company should have:

- Email protection
- Employee awareness training
- Multi-factor authentication (MFA)
- And access controls

Scenario 3 : DORA and Incident Management

A payment company's online platform suddenly stops working because of a ransomware attack.

Question:

What should the company do first?

Solution :

The company should :

- Activate its incident response plan,
- Isolate affected systems,
- Stop the attack from spreading,
- Inform internal teams,
- Start recovery actions.

2.9 Cybersecurity Measures

DORA requires financial companies to use strong protection.

Examples of cybersecurity measures :

- Strong passwords
- Multi-factor authentication (MFA)
- Software updates
- Antivirus / endpoint protection
- Access control
- Firewalls
- Employee training
- Phishing awareness
- Monitoring tools

These controls reduce the chance of attack or damage.

DORA says: protect your systems before something bad happens.

Example 1: Phishing Email

An employee receives an email:

“Urgent! Reset your account now.”

He clicks the link and enters his password.

Risk:

- Hackers may steal credentials.

DORA lesson:

- train employees
- use MFA
- use email protection
- detect suspicious activity quickly

Example 2 : Outdated Software

A company does not update its software for 1 year.

Risk :

- Known security weaknesses may be exploited.

DORA lesson

- patch management
- regular updates
- vulnerability checks

2.10 Incident response

An ICT incident is a digital problem that affects systems or services.

Examples

- banking app outage
- payment system crash
- ransomware attack
- data leak
- cloud outage
- server failure
- login system failure

What is incident response ?

It means the company must know:

- what happened
- how serious it is
- how to stop the damage
- how to restore services
- who should be informed
- what should be documented

DORA says: when a digital incident happens, the company must respond in a clear and organized way.

Incident response model

1. Detect

Notice the problem quickly.

2. Understand

What happened? Which systems are affected?

3. Contain

Stop the problem from getting worse.

4. Recover

Restore systems and services.

5. Review

Learn from the incident.

Incident response example:

A mobile banking app stops working for 3 hours.

What should the company do?

- Detect the outage
- Identify affected systems
- Inform the response team
- Contact the provider if needed
- Restore service
- Check customer impact
- Document the incident
- Review what caused the issue

Regular Testing

DORA says companies must test their resilience regularly.

It is not enough to say:

- “We have a plan.”
- “We have backups.”
- “We are prepared.”

The company must **test** these things.

Why?

Because sometimes a plan looks good on paper but fails in real life.

Testing example

Example 1: Backup Test

The company makes backups every day.

But it never tests restoring them.

Problem

The backup may be damaged or incomplete.

DORA lesson

- test recovery regularly
- check how long recovery takes
- verify data quality

Incident Recovery

DORA requires financial companies to report important ICT incidents.

If a serious digital incident happens, the company may need to inform the supervisory authority.

Why is this important?

Because it helps:

- transparency
- better coordination
- regulatory oversight

- faster response
- better protection for the sector

Example :

A payment platform is unavailable for many hours and thousands of customers are affected.

This may need to be reported.

Simple sentence

DORA says serious digital incidents should not be hidden. They should be reported when required.

2.11 Third-party risk management

Financial companies often depend on:

- cloud providers
- software companies
- data centers
- managed service providers
- external security providers

If these external providers fail, the financial company may fail too.

Using an external provider does not remove the risk. The company must still manage that risk.

Example 1: One Cloud Provider Only

A bank stores all systems in one cloud provider.

Risk:

If that provider has a major outage, many services stop.

DORA action

- identify the provider as critical
- monitor it
- review the contract
- create contingency plans

Example 2 : Security Provider Failure

A payment company uses an external cybersecurity monitoring service.

The provider stops working for 2 days.

Risk :

The company may not detect attacks.

DORA action

- define responsibilities clearly
- monitor provider performance
- have backup arrangements

2.12 What DORA expects from companies

Under DORA, a financial company should:

- know its critical systems
- know its important risks
- protect systems and data
- prepare for incidents
- test recovery and resilience
- manage external providers
- report serious incidents
- improve after problems

2.13 PRACTICAL EXERCISE 1

A small payment company uses:

- one mobile payment app
- one main server
- one cloud provider
- employee email accounts
- customer payment data

The company has these problems:

- Employees use weak passwords
- Backups exist, but they are never tested
- The company depends on one cloud provider only
- There is no written incident response plan
- The manager is not informed quickly during problems

Questions :

- 1) Identify **5 risks** in this scenario.
- 2) Which risks are related to **cybersecurity**?
- 3) Which risks are related to **resilience / continuity**?
- 4) Which risk is related to **third-party dependency**?

Solution :

1. Five risks

- weak passwords
- untested backups
- dependency on one cloud provider
- no incident response plan
- late management escalation

2. Cybersecurity risks

- weak passwords

3. Resilience / continuity risks

- untested backups
- no incident response plan
- late escalation

4. Third-party dependency risk

- dependence on one cloud provider

Some risks are security risks, and some are resilience risks. DORA covers both.

2.14 EXERCISE 2 – True or False

Say whether each statement is **True** or **False**.

- 1) DORA is only for banks.
- 2) DORA is an EU regulation.
- 3) DORA only focuses on hackers.
- 4) DORA also considers third-party ICT providers.
- 5) Testing backups is important under DORA.
- 6) A serious ICT incident may need to be reported.
- 7) If a cloud provider fails, the financial company may also be affected.
- 8) DORA helps reduce systemic risk.

Solution :

- 1) **False**
- 2) **True**
- 3) **False**
- 4) **True**
- 5) **True**
- 6) **True**
- 7) **True**
- 8) **True**

2.15 PRACTICAL EXERCISE 3

Case Study – Secure Pay

Secure Pay is a European payment company.

It offers:

- online payment services
- a mobile app
- customer accounts

It uses :

- one major cloud provider
- customer databases
- digital payment systems
- employee laptops
- an external IT support provider

Incident

One morning :

- The mobile app stops working for **6 hours**
- Customers cannot make payments
- The company learns that the cloud provider has a major outage
- The company has backups, but they were **not tested recently**
- There is **no clear incident response plan**
- Management is informed **late**
- The company is unsure if the incident should be reported
- Customers complain on social media

QUESTIONS – CASE STUDY

- 1) What are **at least 5 DORA-related weaknesses** in this case?
- 2) Why is the cloud provider considered important?
- 3) What should the company do **immediately**?
- 4) What should the company improve in the next 3 months?
- 5) How does this case show the importance of DORA?

Solution:

1. Five DORA-related weaknesses

Possible answers:

- major service outage
- customers cannot make payments
- heavy dependence on one cloud provider
- backups not tested
- no incident response plan
- late management escalation
- unclear reporting process
- weak communication during crisis

2. Why is the cloud provider important?

Because :

- it supports critical services
- the company depends on it
- its outage directly affects customers
- it is a critical third-party ICT provider

The cloud provider is important because the company relies on it to deliver financial services.

3. Immediate actions

The company should:

- Identify the cause of the outage
- Coordinate with the cloud provider
- Activate crisis management
- Inform management immediately
- Assess the impact on customers
- Document the incident
- Evaluate whether reporting is required

4. Improvements for the next 3 months

The company should:

- Create a formal incident response plan
- Test backups and recovery regularly
- Improve third-party risk management
- Define clear reporting rules
- Strengthen communication and escalation
- Review contracts with the cloud provider
- Run resilience exercises
- Improve customer communication procedures

3. DORA Regulation

3.1 When was DORA adopted?

DORA was officially adopted by:

- The European Parliament
- The Council of the European Union

DORA became an official EU regulation on 14 December 2022. This means it is not only a recommendation. It is a real legal requirement for organizations that are in scope. A regulation is stronger than a simple guideline. Companies must follow it.

EU saw several growing dangers:

A. More cyberattacks

- phishing
- ransomware
- hacking
- malware
- account compromise

Example :

“A hacker attacks a bank’s online platform and customers cannot access their accounts.”

B. More IT incidents

- system outages
- software failures
- network problems
- database issues
- failed updates

Example :

“A payment system crashes during a busy day, and customers cannot make transactions.”

C. More dependence on third parties

Many financial companies depend on:

- cloud providers
- external software vendors
- IT service providers
- outsourcing partners

Example :

“If a cloud provider fails, the financial company may also stop working.”

3.2 Why is DORA important for financial stability?

This is important because in finance, an IT problem is not only a technical problem.

It can affect :

- customers
- payments
- trust
- access to money
- business operations
- the wider market

If a social media website stops working, it is a problem. But if a major bank or payment company stops working, it can affect many customers, businesses, and even the financial system. That is why resilience is very important in finance

Then:

- ➔ DORA is a European law for banks and other financial companies. It was created because these organizations use many digital systems, and this creates more cyber risks and technical problems. DORA helps them prepare, continue working, protect customers, and recover quickly when something goes wrong.
- ➔ DORA is a European law created to help financial companies manage technology and cyber risks in the same way across the EU. It was adopted in December 2022, started in January 2023, and became fully applicable on 17 January 2025. Its main goal is to create one clear and common set of rules so banks, insurance companies, and other financial organizations can better prevent, manage, and recover from digital problems.
- ➔ For example, before DORA, different financial companies could follow different ICT risk rules. With DORA, the EU wants everyone to follow a more unified approach.

4. DORA Requirement

DORA has five main requirement areas.

- First, financial organizations must manage ICT and cyber risks.
- Second, they must detect, handle, and report incidents.
- Third, they must test their systems and recovery plans to make sure they are ready.
- Fourth, they must manage risks from third parties like vendors or cloud providers.
- Fifth, they can share cyber threat information to improve security. These five areas help organizations become stronger and more resilient.

Goal:

Be prepared, stay operational, and recover quickly.

Scenario 1 : Cyber Risk Management in DORA

A bank uses an old online banking platform.

The IT team notices that the platform has security weaknesses and could fail during a cyberattack.

Question:

What should the bank do under DORA?

Solution :

The bank should :

- Identify the risk,
- Assess the impact,
- Improve security controls,
- Update the system,
- Monitor the risk regularly.

Scenario 2 : DORA Incident Detection and Reporting

A payment company suffers a ransomware attack.
Its online payment service becomes unavailable for several hours.

Question:

What should the company do under DORA?

Solution :

The company should :

- Detect the incident quickly,
- Activate its incident response plan,
- Contain the attack,
- Recover the service,
- Classify the incident,
- Report it to the authority if it is significant.

Scenario 3 : DORA Testing Requirements

A financial firm says it has a backup system.
But when the main server fails, the team realizes the backup has never been tested.

Question:

Why is this a problem under DORA?

Solution:

Because DORA requires regular testing, such as:

- Backup and recovery testing,
- Security control testing,
- Incident response exercises,
- Resilience testing of critical systems.

Scenario 4 : DORA and Cloud Provider Responsibility

A bank stores customer data with a cloud provider.

One day, the provider has a major outage, and the bank's online services stop.

Question:

Who is responsible under DORA?

Solution:

The bank is still responsible.

It should :

- Assess the vendor's risks,
- Review contracts carefully,
- Monitor the provider,
- Prepare contingency or exit plans.

Scenario 5: DORA and Cyber Threat Sharing

A financial company discovers a new phishing campaign targeting customer login pages.

It notices other banks may face the same attack.

Question:

Can the company share this threat information?

Solution:

Yes.

DORA allows organizations to share relevant cyber threat information in a secure and appropriate way to help others:

- recognize the threat,
- protect their systems,
- and react faster.

5. Penalties

If a financial organization does not follow DORA, the authorities can apply penalties. They can ask the organization to stop the non-compliant activity, stop certain practices, pay fines, provide information for investigation, and in some cases make the violation public. In simple terms, DORA is a serious regulation, and companies must follow it or face regulatory consequences.

For example, if a financial company does not manage ICT risks properly or ignores major incident obligations, the regulator may require corrective actions, impose a fine, or publicly report the noncompliance.

Then:

➔ If a company does not follow DORA, authorities may:

- Order it to stop the violation
- Require corrective actions
- Impose fines
- Investigate the issue
- Make the issue public in some cases

Scenario 1: DORA Penalties

A financial company does not manage ICT risks properly.
It also ignores a major cyber incident and does not report it to the regulator on time.

Later, the regulator discovers that:

- The company had weak controls,
- The incident response was poor,
- Reporting obligations were not respected.

Question:

What can the regulator do under DORA if the company does not comply?

Solution:

The regulator can take several actions, such as:

- Require corrective actions to fix the problem
- Order the company to stop the non-compliant activity
- Stop certain risky practices
- Request documents and information for investigation
- Impose a financial penalty (fine)
- Serious cases, publicly report the non-compliance